

Management should use the BIA and risk management processes to identify and monitor continuity risks for an entity. Once management determines the risk, there are four common strategies to address that risk: risk acceptance, risk mitigation, risk transference, and risk avoidance. Risk transference, such as obtaining insurance, may allow management to recover financial losses or expenses resulting from an event and can be an effective capital management tool; however, insurance should not be a substitute for effective controls or continuity and resilience planning. Management's continuity and resilience planning efforts should focus on risk mitigation and avoidance strategies, and where appropriate, risk acceptance strategies. These strategies are covered more in depth throughout this booklet. Refer to the *IT Handbook's* "Management" booklet for additional information.

Management at large and systemically important entities whose failure could trigger a broader financial disruption should assess the likelihood and impact of a disruption, both to the entity and the entire financial sector. These entities are a critical component of the broader financial system and should incorporate scenarios of disruptions impacting the financial sector into the entity's BCM processes.

The *Interagency Paper on Sound Practices to Strengthen the Resilience of the U.S. Financial System (Sound Practices Paper)*¹³ outlines practices for financial industry participants that perform clearing and settlement activities for critical financial markets (core firms) and institutions that process a significant share of transactions in critical financial markets (significant firms). Regulators have notified all participants that meet the definition of a core or significant firm as set forth in the *Sound Practices Paper*. Because core and significant firms participate in one or more critical financial markets, and their failure to perform critical activities by the end of a business day could present systemic risk to financial systems, their role in financial markets should be addressed as part of the business continuity planning process.

¹³ Refer to the *Interagency Paper on Sound Practices to Strengthen the Resilience of the U.S. Financial System* issued by the [SR Letter 03-9](#) (FRB), [Bulletin 2003-14](#) (OCC), and [Release No. 34-47638](#) (U.S. Securities and Exchange Commission (SEC)). Also refer to [68 Fed. Reg. 17809](#).

III.A Business Impact Analysis

Action Summary

Management should develop a BIA that identifies all business functions and prioritizes them in order of criticality, analyzes related interdependencies among business processes and systems, and assesses a disruption's impact through established metrics. The BIA should define recovery priorities and resource dependencies for critical processes.

Examiners should review the following as part of the BIA process:

- Identification of critical business functions.
- Identification of interdependencies across business units.
- Identification and analysis of disruptive events.
- Reasonableness of recovery objectives.
- Communication of BIA results throughout the entity.
- Comprehensiveness of management's BIA review.

A BIA is the process of identifying the potential impact of disruptive events to an entity's functions and processes. A BIA allows management to identify and analyze gaps in critical processes that would prevent the entity from meeting its business requirements. The BIA generally lists recovery priorities and resources on which critical processes depend (e.g., work flow analysis¹⁴). Through the BIA process, management should identify interdependencies among critical operations, departments, personnel, services, and the functions with the greatest exposure to interruption. Management should identify resources on which these functions and processes depend and exposures that would warrant further protective measures. Furthermore, the BIA should include financial and other resource costs (e.g., the loss of business, and exposure to legal and regulatory consequences) needed to recover and restore business functions and processes.

The time and resources to complete the BIA depends on the entity's size and complexity. Complex entities may have multiple BIAs for various business lines, subsidiaries, or other organizational separations. Information from the ERM, such as business processes and risk appetites, may facilitate the BIA development.

¹⁴ The work flow analysis can assist in documenting interdependencies among critical operations, departments, personnel, and services.

III.A.1 Identification of Critical Business Functions

Completing the BIA generally involves gathering information regarding business functions, impacts from disruptions, and business interdependencies; analyzing this information; and establishing recovery objectives. Critical business functions,¹⁵ including support activities (e.g., help desk, call center, human resources, and payroll), systems, and interrelationships may be analyzed in several ways. Work flows, interviews, organizational charts, network diagrams/topologies, data flow diagrams, succession plans, or delegations of authority for key personnel may help management identify business processes and hierarchies.

Management should inventory the entity's critical assets (e.g., people, hardware, software, data, information, and cash) and infrastructure (e.g., network connectivity, communication lines, facilities, and utilities), including those provided by third-party service providers. Furthermore, management should consider supporting activities (e.g., technology support, payroll, contracting) and software (e.g., email, office productivity suites), geographic locations, and unique aspects (e.g., proprietary hardware and software, documentation, or other specialized supplies). Management should also inventory third-party service providers, including specific services they provide. The methodology used should be repeatable, allowing management to reevaluate information after significant changes.

III.A.2 Interdependency Analysis

The BIA process allows management to identify, analyze, and prioritize interdependencies among business functions and systems for alignment with resilience and recovery objectives. The analysis allows management to evaluate interdependent business functions, systems, and shared resources.

During its analysis, management should identify single points of failure, which may include telecommunication lines, network connections between branches, backups that become corrupted, reliance on one power source, or data center locations in close geographic proximity. Personnel can be a single point of failure if there are no cross-trained personnel to back up their responsibilities. Important interdependencies that should be considered include the following:

- Internal systems and business functions, which could include customer services, production processes, hardware, software, application programming interfaces (i.e., code that allows two programs to communicate with each other), data, and documentation of vital records for legal/statutory or process documentation.
- Third-party service providers (e.g., core processing, online and mobile banking, settlement activities, and disaster recovery services), key suppliers (e.g., hardware, software, and utility providers), and business partners and their roles and responsibilities for resilience and recovery.

The BIA will assist management in forming contract and service-level agreement (SLA) requirements for availability and reliability of each service. For pre-existing contracts and SLAs,

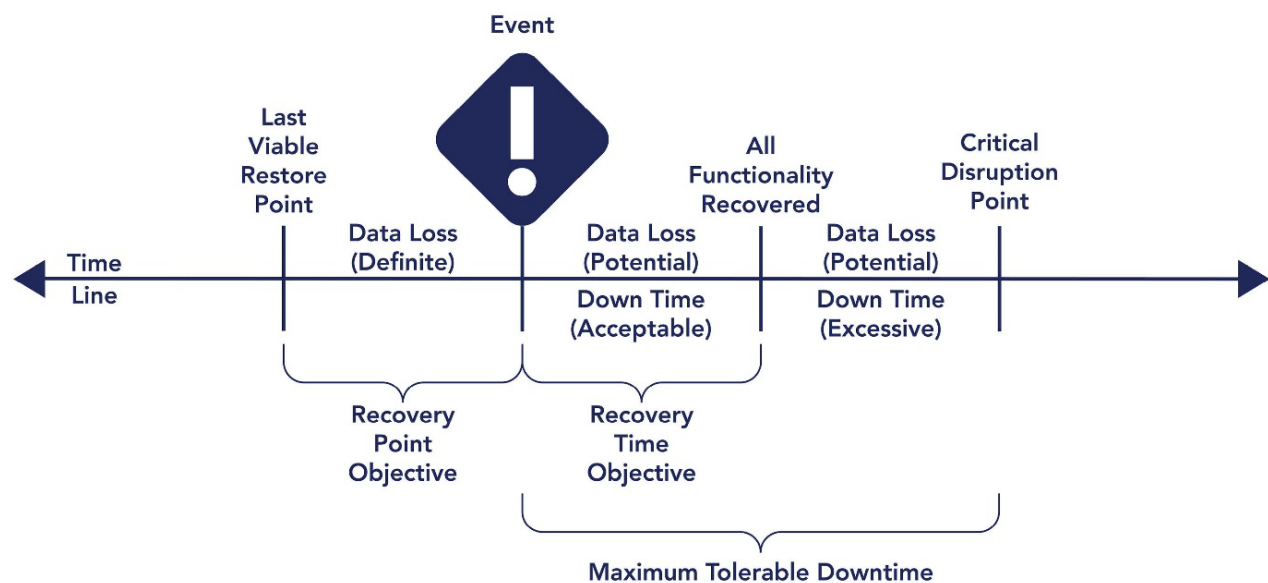
¹⁵ The term "function" can consist of one or more processes.

management should confirm that the contract and SLA requirements align with management's and the customer's continuity and resilience expectations.

III.A.3 Impact of Disruption

Through the BIA process, management should evaluate the potential impact of disruptive events, including operational, financial, and reputational impacts. Management should establish recovery objectives after determining a disruption's impact. Common measurements include recovery point objective (RPO), recovery time objective (RTO), and maximum tolerable downtime (MTD). Where applicable, these measurements should be evaluated for alignment with third-party service providers' contracted recovery expectations.

Figure 3: Recovery Objectives (Relative to an Event)



As illustrated in figure 3, the RPO represents the point in time, before a disruption, to which data can be recovered (given the most recent backup copy of the data) after an outage. Refer to section [IV.A.2, “Cyber Resilience,”](#) for additional information regarding backups.

As illustrated in figure 3, the RTO defines the maximum amount of time that a system resource can remain unavailable before there is an unacceptable impact on other system resources and business processes. Determining the RTO is important for selecting appropriate technologies and strategies. When it is not feasible to meet an RTO, management should verify whether the RTO is realistic, initiate an action plan and milestone(s) to document the situation, and, when appropriate, plan for its mitigation. Management should consider interrelated RTOs for each business function to determine the total downtime caused by a disruption. Establishing realistic RTOs assists management in determining a critical path and hierarchy for recovery. For example, a process with a shorter RTO that is dependent upon on a process with a longer RTO may indicate a gap that should be analyzed further.

Whether driven by customer expectations or technological advancement, previously established RTOs that were a few hours in duration may now require near real-time recovery. Therefore, it may be appropriate for management to reevaluate currently acceptable RTOs.

As illustrated in figure 3, the MTD represents the total amount of time the system owner or authorizing official is willing to accept for a business process disruption and includes all impact considerations. The MTD is important for contingency planners when selecting an appropriate recovery method and developing the scope and depth of recovery procedures. Examiners may encounter other terminology to describe MTD (e.g., maximum allowable downtime).

Failure to meet established metrics, such as RPO, RTO, and MTD, may have operational impacts, including discontinued or reduced service levels, inability to meet security requirements, workflow disruptions, supply chain disruptions, and delays of business initiatives. The financial impact could include the loss of revenue, increased costs, or fines and penalties.

III.B Risk Assessment

Action Summary

Management should evaluate the likelihood and impact of potential disruptions and events. As part of this evaluation, management should consider the geographical area where the entity operates. Additionally, management should consider the risks and threats that could affect the entity's third-party service providers. Once management identifies scenarios; evaluates specific threats to the controls, strategies, and plans; and understands the entity's risk exposure, management should develop risk treatment strategies (including risk acceptance or risk transfer) based on the entity's risk appetite.

Examiners should review the risk assessment and determine whether it addresses the impact and likelihood of disruptions of the entity's information services, technology, personnel, facilities, and services provided by third parties. Specifically, examiners should review whether the following types of events are included in the risk assessment:

- Natural events such as fires, floods, severe weather, air contaminants, and hazardous spills.
- Technical events such as communication failure, power failure, equipment and software failure, transportation system disruptions, and water system disruptions.
- Malicious activity, including fraud, theft, blackmail, sabotage, cyber attacks, and terrorism.
- International events that may affect services (e.g., political instability and economic disruptions).
- Low likelihood and high impact events (e.g., terrorist attacks or pandemic events).

Risk assessment is the process of identifying risks to operations, organizational assets, individuals, and other organizations. Risk assessments incorporate threat and vulnerability

analyses and address the appropriate mitigations. As part of risk assessment processes, information from the ERM can be leveraged, such as business process documentation, critical risks, impacts, and tolerances. Management should use risk assessments to identify, measure, and mitigate risk exposures to critical functions and processes identified by the BIA. Furthermore, the risk assessment process may result in changes to the BIA. For example, management may prioritize business processes based on their importance to strategic goals and safe and sound practices; however, after developing threat models, results may necessitate prompt alteration of initial priorities or recovery plans.

III.B.1 Risk Identification

While management performs risk assessments, the focus of business continuity risk identification is on the resilience of the entity. While the causes of events can vary greatly, many of the effects do not. According to the Federal Emergency Management Agency (FEMA), threats and hazards can be categorized as natural, technological, and adversarial or human-caused.¹⁶ Each of these threats and hazards can be subcategorized, for example as internal (e.g., malicious insider or human error) or external, systemic or non-systemic, deliberate or inadvertent, and with or without warning. Although the characteristics of each hazard and threat (e.g., speed of onset, size of the affected area) may be different, the general tasks for recovering operations are the same. Management should address common operational functions in the business continuity plan (BCP) instead of having unique plans for every type of hazard or threat. Planning for all threats and hazards ensures that, when addressing emergency functions, planners identify common tasks and the personnel responsible for accomplishing the tasks.

Management should evaluate potential risks that are in the entity's geographic area. For example, entities could be located in flood-prone areas, earthquake zones, terrorist targets, or areas affected by tornados or hurricanes. In addition to geographic areas, management should also assess geopolitical risk and the potential for retaliatory cyber attacks. For example, U.S. sanctions against a nation-state could increase the risk of cyber attacks against critical infrastructure(s).

Management should coordinate business continuity risk identification efforts throughout the entity. Individual business units within larger entities should coordinate risk identification activities to identify systemic threats to the overall entity. Management should identify and inventory the entity's internal and external assets, types of threats and hazards, and existing controls as an important part of effective risk identification. Refer to the *IT Handbook's* "Management" booklet for additional information.

Furthermore, management should identify cyber security risks (refer to the *IT Handbook's* "Information Security" booklet for additional information), which should be gathered as part of the risk assessment process. Cyber security can pose risk to customer information as discussed in

¹⁶ Refer to FEMA's [Comprehensive Preparedness Guide \(CPG\) 101 Version 2.0](#). Non-FFIEC agency documents are included for illustrative purposes of common risks and are not supervisory expectations.

the *Interagency Guidelines Establishing Information Security Standards*¹⁷ that implement the Gramm-Leach-Bliley Act (GLBA).

Management should coordinate with external sources to obtain information about hazards and threats. External sources include industry information-sharing groups (e.g., Financial Services Information Sharing and Analysis Center (FS-ISAC)), and local, state, and federal authorities¹⁸ that provide timely and actionable information about hazards and threats. In addition, sharing information about events at an entity may help others identify, evaluate, and mitigate cybersecurity threats and vulnerabilities. Information about hazards and threats should be considered in the BIA, risk assessment, and other BCM processes. Refer to the *IT Handbook's* "Information Security" booklet for additional information.

One component in the risk identification process is the gathering and assessment of threat intelligence, which National Institute of Standards and Technology (NIST) defines as "information that has been aggregated, transformed, analyzed, interpreted, or enriched to provide the necessary context for decision-making processes." Management should integrate its threat-intelligence process with the BCM function.

Threats are potentially magnified when entities and their third-party service providers are tightly interconnected. An incident affecting one entity or third-party service provider can result in cascading impacts that quickly affect other service providers, institutions, or sectors. The term "supply chain risk" in BCM may be used to represent the risk related to the interconnectivity among the entity and others. A critical failure at a third-party service provider could have large-scale consequences. Management should identify interconnectivity points between the entity and its third-party service providers, as well as between other entities and third-party service providers. Documenting the flow of transactions, such as developing formal process diagrams, may help management identify interdependencies and end-to-end processes.

III.B.2 Likelihood and Impact

Management should evaluate the likelihood and impact of disruptive events. Risks may range from those with a high likelihood of occurrence and low impact, such as brief power interruptions, to those with a low probability of occurrence and high impact, such as pandemics. The most difficult risks to address are those that may have a high impact on the entity but a low probability of occurrence. The Department of Homeland Security's (DHS) *National Infrastructure Protection Plan*¹⁹ provides examples of risk measurement processes and methodologies to help analyze risks.

¹⁷ Refer to the *Interagency Guidelines Establishing Information Security Standards* issued by [12 CFR 364, Appendix B](#) (FDIC); [12 CFR 208, Appendix D-2](#) and [12 CFR 225, Appendix F](#) (FRB); and [12 CFR 30, Appendix B](#) (OCC). Also refer to *Guidelines for Safeguarding Member Information*, [12 CFR 748, Appendix A](#) (NCUA).

¹⁸ Examples include ChicagoFIRST county and state government, the DHS's National Terrorism Advisory System, FEMA, and the World Health Organization.

¹⁹ Refer to DHS's [National Infrastructure Protection Plan](#).

As part of the assessment, management should quantify the impacts and define loss criteria as either quantitative (financial) or qualitative (e.g., impact to customers, reputational impact). The BCM risk assessment should be commensurate with the entity's risk and complexity and should include reasonably foreseeable events. Worst-case scenarios, such as destruction of the facilities and loss of life, should be addressed. State and local authorities may assist management with identifying specific risks or exposures for geographic locations, and special requirements for accessing emergency zones.

Management should also assess whether its third-party service providers consider the likelihood of a disruption based on the geographic location of facilities, their susceptibility to threats (e.g., location in a flood plain), and the proximity to critical infrastructure (e.g., power grids, telecommunications, nuclear power plants, airports, major highways, and railroads).

Management should determine the potential severity of threats and estimate the disruption's impact under various threat scenarios as it assesses the likelihood and impact of a disruption. The results may be scored quantitatively (e.g., based on a numerical ranking) or qualitatively (e.g., high, medium, and low) and then prioritized. Refer to the *IT Handbook's* "Management" booklet for additional information.

Once management identifies scenarios, it should evaluate specific threats to the entity's controls, strategies, and plans. The difference, or the gap, between the risks from likely foreseeable threats and the mitigation provided by current controls, represents the risk exposure. Management should develop strategies to manage risk, which could include risk mitigation, avoidance, acceptance, or risk transfer, based on the entity's risk appetite.

IV Business Continuity Strategies

Action Summary

The board and senior management should develop effective strategies to meet resilience and recovery objectives. Effective oversight generally includes guidelines to achieve defined business continuity objectives.

Examiners should review BCM strategies and determine whether the strategies:

- Address personnel, processes, technology, and facility issues.
- Address critical business risks in the operating environment (e.g., mitigate specific or unique threats, such as cyber threats or loss of critical third-party service providers).
- Outline a combination of backup, replication, and storage methods for data protection.
- Provide for high redundancy levels in the telecommunications infrastructure.
- Detail a consistent change management process throughout the entity.
- Include alternatives for any proprietary systems.
- Include provisions for appropriate international business activities, where applicable.

Business continuity strategies are developed after the BIA and risk assessment process. These strategies should be risk-based and address all foreseeable risks, including non-technology risks (e.g., transaction, liquidity, and reputation risks). Strategies should include allocation of resources to meet resilience and recovery objectives. Strategies should be validated to confirm that they are viable and sufficient for peak work volumes. For example, the increased reliance on and interconnectivity of technology makes it less feasible for many entities to operate manually for an extended period, if at all.

Strategies should include the potential impact to personnel, processes, technology, facilities, and data. Personnel-related strategies may include logistical arrangements to transport or house staff at alternate facilities. In addition, management may establish alternate methods for communicating with employees, customers, and external parties. Process-related strategies may include redundant work sites for business-line operations or manual processes. Technology-related strategies may include fully equipped backup data centers or cloud providers. Backup strategies should include data files, operating systems, and applications and utilities. Facilities-related strategies may include geographic diversity or multiple power sources to reduce single point of failure risk.

Data protection strategies typically include a combination of backup, replication, and storage to achieve different levels of continuity and resilience. For example, it may be appropriate to deploy more automated, scalable solutions, such as data replication to a cloud. Management should develop comprehensive strategies to protect data, such as:

- Integrating operational, continuity, and resilience strategies to protect data based on recovery objectives.
- Designing a process to preserve the integrity and availability of data from threats.
- Monitoring the effectiveness and efficiency of data protection solutions.

Strategies should address critical business risks in the operating environment. Management should consider strategies to mitigate specific or unique threats, such as cyber threats or loss of critical third-party service providers. The specific strategy in response to an event may be different based on the entity's capabilities. Management should determine what alternatives exist for proprietary systems given the significant, unique risks to an entity's business activities. For example, some entities use internally developed assets (e.g., spreadsheets or other tools) that are critical for certain calculations within a business unit, which are often overlooked, including where and how they are stored, during the risk assessment and BIA processes. Furthermore, management should also consider access capabilities for voice and data, mapping technology infrastructure to employee needs, and internal and external capacity (including remote capacity) to determine whether telecommuting strategies are sufficient.

Strategies could include cloud architectures, virtualization, and other technologies. Cloud solutions may provide a cost-effective and high-availability environment. Independent of the strategies selected for architecture and data protection, management should still be responsible for data integrity and overall resilience. Cloud-based disaster recovery services²⁰ may be considered as part of resilience programs. Refer to section [V.C.1, "Data Center Recovery Alternatives,"](#) for additional information.

²⁰ Refer to the FFIEC's statement on [Outsourced Cloud Computing](#).